Brute Force Attack Simulation & Authentication Security Analysis

Autor: Olvis Duran
Rol: Estudiante de Informática y Ciberseguridad
Fecha: marzo 2026

1. Introducción

En el ámbito de la ciberseguridad, los sistemas de autenticación representan una de las primeras líneas de defensa contra accesos no autorizados. Sin embargo, estos sistemas pueden ser vulnerables a ataques de fuerza bruta, una técnica en la que un atacante intenta múltiples combinaciones de credenciales hasta encontrar las correctas.

Este proyecto presenta una simulación de ataques de fuerza bruta en aplicaciones web dentro de un entorno controlado y con fines estrictamente educativos. El objetivo principal es comprender cómo funcionan estos ataques, analizar el comportamiento del sistema ante múltiples intentos de autenticación y proponer medidas de seguridad efectivas para mitigar este tipo de amenazas.

2. Objetivos

Objetivo General

Analizar el funcionamiento de los ataques de fuerza bruta en sistemas de autenticación web mediante simulaciones controladas.

Objetivos Específicos

- Simular ataques de fuerza bruta utilizando diferentes técnicas automatizadas
- Evaluar la respuesta del sistema ante múltiples intentos de autenticación
- Identificar posibles vulnerabilidades en formularios de login
- Analizar el impacto del uso de diccionarios de contraseñas
- Proponer medidas de mitigación basadas en buenas prácticas de seguridad

3. Metodología

Para el desarrollo de este proyecto se adoptó un enfoque práctico basado en la simulación de ataques dentro de un entorno controlado. Se diseñaron y ejecutaron diferentes scripts en Python con el fin de replicar el comportamiento de un atacante real, sin comprometer sistemas reales.

◆ Enfoque de trabajo

Se utilizó una metodología de tipo experimental, en la cual se ejecutaron múltiples pruebas automatizadas contra un sistema de autenticación de prueba. Este enfoque permitió observar el comportamiento del sistema ante intentos repetitivos de acceso.

◆ Fases del proceso

1. Diseño del entorno de prueba:
Se definió una URL de prueba (`example.com/login`) para evitar el uso de plataformas reales y garantizar un entorno ético y seguro.

2. Desarrollo de scripts:
Se implementaron diferentes scripts en Python para simular ataques desde distintas perspectivas:

- Peticiones HTTP directas
- Automatización de navegador
- Ejecución paralela mediante hilos

3. Ejecución de pruebas:
Se realizaron múltiples intentos de autenticación utilizando combinaciones de usuario y contraseña.

4. Recolección de resultados:
Se analizaron las respuestas del sistema para determinar si las credenciales eran válidas o inválidas.

5. Análisis de seguridad:
Se evaluaron los posibles puntos débiles del sistema y se identificaron mecanismos de defensa necesarios.

4. Herramientas utilizadas

Durante el desarrollo del proyecto se utilizaron las siguientes herramientas:

- **Python:** Lenguaje principal para el desarrollo de scripts
- **Requests:** Para realizar peticiones HTTP automatizadas
- **Selenium:** Para simular interacción real con el navegador
- **Threading:** Para ejecutar múltiples intentos en paralelo
- **Google Chrome:** Navegador utilizado para pruebas con Selenium

5. Descripción de los Scripts

◆ brute_force_requests.py

Este script simula un ataque de fuerza bruta mediante el envío de múltiples solicitudes HTTP al servidor. Permite probar combinaciones de usuario y contraseña de forma rápida y eficiente.

◆ brute_force_selenium.py

Este script utiliza Selenium para automatizar el navegador e interactuar con formularios web como lo haría un usuario real. Es útil para analizar sistemas con contenido dinámico o protegidos por JavaScript.

◆ threading_attack.py

Este módulo permite ejecutar múltiples intentos de autenticación de forma simultánea mediante el uso de hilos, aumentando significativamente la velocidad del ataque en el entorno de prueba.

6. Resultados

Durante las pruebas realizadas se observaron los siguientes resultados:

- El sistema respondió correctamente a intentos fallidos de autenticación
- No se implementaron mecanismos de bloqueo tras múltiples intentos
- El uso de múltiples hilos incrementó la velocidad de ejecución
- La automatización con Selenium permitió simular comportamientos más realistas

7. Análisis de Seguridad

A partir de los resultados obtenidos, se identificaron varios aspectos relevantes:

- La ausencia de limitación de intentos facilita ataques automatizados
- La falta de CAPTCHA permite la ejecución continua de scripts
- No implementar autenticación multifactor incrementa el riesgo
- Los mensajes de error pueden proporcionar información útil a un atacante

8. Recomendaciones

Para mitigar ataques de fuerza bruta, se proponen las siguientes medidas:

- Implementar bloqueo temporal de cuentas tras múltiples intentos fallidos
- Integrar sistemas CAPTCHA dinámicos
- Utilizar autenticación multifactor (MFA)
- Limitar el número de intentos por dirección IP
- Monitorear y analizar logs de acceso en tiempo real

9. Perspectiva Blue Team

Desde el punto de vista defensivo, los ataques de fuerza bruta pueden detectarse mediante el monitoreo de eventos de autenticación. Un analista de seguridad puede identificar patrones sospechosos como múltiples intentos fallidos en un corto período de tiempo y activar mecanismos de respuesta.

10. Consideraciones Éticas y Legales

Este proyecto fue desarrollado exclusivamente con fines educativos. Todas las pruebas fueron realizadas en entornos controlados y autorizados. El uso de estas técnicas en sistemas reales sin permiso constituye una actividad ilegal.

11. Limitaciones

- El entorno de prueba no incluye protecciones avanzadas reales
- No se implementaron mecanismos como CAPTCHA o WAF
- No se simuló evasión avanzada de detección

12. Conclusión

La simulación de ataques de fuerza bruta permite comprender las debilidades en los sistemas de autenticación y resalta la importancia de implementar medidas de seguridad robustas. Este tipo de análisis es fundamental tanto para equipos de Red Team como de Blue Team, contribuyendo al fortalecimiento de la seguridad en aplicaciones web.